

Pre-Lab Audit Package

Module: pqc_crypto_module v0.1.0 **Platform:** Cerulean Ledger DLT **Date:** 2026-04-28

Disclaimer: This package does not imply FIPS 140-3 validation or CMVP certification. It is a self-assessment exercise prepared to reduce technical and documentation risk before engaging a FIPS 140-3 accredited laboratory.

Purpose

This package contains a comprehensive pre-lab evidence set for a mock FIPS 140-3 review of pqc_crypto_module v0.1.0, the post-quantum cryptographic module used by the Cerulean Ledger blockchain platform.

The goal is to identify and document all gaps honestly so that formal lab engagement begins with a clear remediation plan rather than surprises.

What Is Ready

- **Module boundary** fully defined and enforced: 11 source files in crates/pqc_crypto_module/src/, 100% boundary compliance (189/189 non-module files verified clean by tests/crypto_boundary.rs)
- **Approved-mode state machine** implemented via AtomicU8 with SeqCst ordering: Uninitialized -> SelfTesting -> Approved -> Error
- **ML-DSA-65** (FIPS 204) sign/verify fully functional and integrated end-to-end with the identity signing provider
- **SHA3-256** (FIPS 202) fully functional with KAT self-tests
- **Self-tests** run before FSM enters Approved state: SHA3 KAT, ML-DSA sign/verify/corrupt KAT, ML-KEM encaps/decaps KAT, continuous RNG test
- **Error state** is fail-closed: all operations rejected when FSM is in Error
- **Key zeroization** via ZeroizeOnDrop on MlDsaPrivateKey (4032B), MlKemPrivateKey, MlKemSharedSecret
- **Legacy algorithms** (Ed25519, SHA-256, HMAC-SHA256) identified as non-approved and runtime-gated
- **RNG failure handling** explicit: CryptoError::RngFailure with no fallback
- **Reproducible build process** defined with Cargo.lock pinning and clean-room Docker build

- **Traceability matrix** mapping 12 requirements to code, tests, and documentation

What Is Not Ready

These gaps are documented honestly. They are the primary topics for lab discussion.

Gap	Severity	Details
ML-KEM-768 is a placeholder	HIGH	<code>encapsulate()</code> and <code>decapsulate()</code> exist structurally but no production consumer uses ML-KEM. Must be completed or removed from the approved list.
No ACVP test vectors	HIGH	KAT self-tests use internal vectors. Official NIST ACVP vectors for ML-DSA-65, ML-KEM-768, and SHA3-256 are not integrated.
No Security Policy document	HIGH	FIPS 140-3 mandatory deliverable. No Crypto Officer Guide or User Guide exists.
No SP 800-90A DRBG	MEDIUM	<code>OsRng</code> via <code>getrandom</code> is used directly. No HMAC-DRBG or CTR-DRBG within the module boundary.
SP 800-90B compliance TBD	MEDIUM	OS entropy source not formally assessed against SP 800-90B.
Non-approved not FSM-blocked everywhere	MEDIUM	<code>ensure_not_approved()</code> guard exists but is not enforced at every non-approved entry point.
Formal Module Specification missing	MEDIUM	Boundary is enforced by test but the formal document required by FIPS 140-3 Section 7.2 does not exist.
Reproducible build unverified	MEDIUM	Process defined but no hash comparison evidence from two independent builds.
No mlock for key memory	LOW	

Gap	Severity	Details
		Private keys could swap to disk. Not required at Level 1 but noted.

Package Contents

File	Description
README.md	This file – package overview and guidance
MOCK_AUDIT_REPORT.md	Hostile-but-fair mock FIPS lab review with 11 classified findings
ACVP_DRY_RUN_PLAN.md	ACVP test vector plan for ML-DSA-65, ML-KEM-768, SHA3-256
FIPS_140_3_IG_CHECKLIST.md	Implementation Guidance checklist covering 17 areas
CLEAN_ROOM_BUILD.md	Reproducible build process with Docker, toolchain pinning, hash comparison
ENTROPY_RNG_EVIDENCE.md	Entropy source chain, continuous RNG test, failure handling, known gaps
VENDOR_EVIDENCE_PACKAGE.md	SBOM plan, 11 dependencies, license review, third-party crypto statement
TRACEABILITY_MATRIX.md	12 requirements mapped to implementation, test, and documentation files
FINDINGS_REGISTER.md	Aggregated findings with severity, owner, status, and lab-intake blocking assessment

How to Use with a Lab

Before lab engagement

1. Resolve the 3 HIGH findings (F-001, F-002, F-010) – these are hard blockers
2. Address MEDIUM findings F-006, F-008, F-011 – strongly recommended
3. Prepare answers for LOW/INFO findings – labs will ask about them

During initial intake

1. Share this entire pre_lab_audit/ directory with the selected CMVP-accredited lab
2. Walk through MOCK_AUDIT_REPORT.md findings together – this shows the lab you have done honest self-assessment

3. Review FINDINGS_REGISTER.md open items and agree on a remediation timeline
4. Use TRACEABILITY_MATRIX.md as the basis for evidence mapping during the evaluation
5. Discuss ENTROPY_RNG_EVIDENCE.md to clarify the RNG approach early – labs have strong opinions on this

Running verification locally

```
# Module unit tests (single-threaded for FSM state isolation)
cargo test -p pqc_crypto_module -- --test-threads=1

# Boundary enforcement test
cargo test --test crypto_boundary

# FIPS readiness tests
cargo test -p pqc_crypto_module --test fips_readiness -- --test-threads=1

# Clean-room reproducible build (requires Docker)
bash scripts/clean_room_build.sh
```

Approved Algorithms

Algorithm	Standard	Status in Module
ML-DSA-65	FIPS 204	Fully functional
ML-KEM-768	FIPS 203	Placeholder (F-001)
SHA3-256	FIPS 202	Fully functional

Non-Approved Algorithms (Legacy)

Algorithm	Usage	Gating
Ed25519	Digital signatures (legacy)	SIGNING_ALGORITHM env var, feature flag
SHA-256	Hashing (legacy)	Runtime gate
HMAC-SHA256	MAC (legacy)	Runtime gate

Dependencies

11 direct dependencies, all MIT/Apache-2.0/BSD licensed. Primary crypto dependency is pqcrypto-mldsa (C backend via pqcrypto-internals). See VENDOR_EVIDENCE_PACKAGE.md for full analysis.

This package was prepared as a self-assessment. All gaps are documented intentionally. The module architecture is sound; the remaining work is primarily documentation deliverables and ACVP integration.